

Threat Modeling: The Discipline

Threat modeling answers four questions:

What are we building? (system boundary, data flows)

What can go wrong? (threats)

Who is attacking and why? (threat actors, motive)

What should we do about it? (countermeasures)

Core vocabulary

Term	Definition
Asset	Something of value – data, systems, reputation
Threat	A potential cause of harm (malware, insider, flood)
Vulnerability	A weakness that a threat can exploit
Risk	Likelihood × Impact of a threat exploiting a vulnerability
Attack surface	All the ways an attacker can interact with the system
Trust boundary	A line across which privilege or trust changes

A simple risk formula

$$\text{Risk} = \text{Threat Likelihood} \times \text{Vulnerability Exploited} \times \text{Impact}$$

If you patch (kill the vulnerability), risk drops even if the threat stays.

The attackers you must know

Script kiddies – low skill, recycled tools

Organized crime – ransomware, extortion, profit

Nation-state / APT – espionage, sabotage, persistence

Insiders – employees, contractors, disgruntled or negligent

Hacktivists – ideology-driven defacement and leaks

STRIDE (attacker's view)

Microsoft's STRIDE names *what* goes wrong per element:

Spoofing – faking identity

Tampering – modifying data

Repudiation – denying actions

Information disclosure – leaking data

Denial of service – breaking availability

Elevation of privilege – gaining more rights

Walk any component through STRIDE and you have a threat list.

Data flow first

Draw the system's data flows (request → app → DB → response). Mark trust boundaries at every hop. Most vulnerabilities hide at trust boundaries – inputs crossing them unvalidated, or privileges assumed on the other side.

← Confidentiality, Integrity &...

Cyber Kill Chain & Attack Life...